ENGINEERING FEEDBACK & DELIVERY PLAN

Zero-Trust Network Access Control System

Machine Learning-Based Behavioral Authentication

Review of the client research proposal
Development of a Zero-Trust Network Access Control System Using Machine Learning-Based Behavioral Authentication

DOCUMENT CONTROL	DETAIL
Document category	Technical feasibility review and proposed implementation plan
Research proponent	Oso Akinyemi Seun
Research institution	Centre of Cybersecurity and Sustainable Development, University of Ilorin
Prepared by	Project Development Consultant
Document status	For client review and scope approval
Date / revision	16 October 2026 | Version 1.0

RECOMMENDATION

Proceed with the research concept. Implement continuous behavioral verification for access to protected web resources, including real authentication, MFA, a machine-learning research pipeline and an enforcement gateway. Treat physical Ethernet/Wi-Fi admission control as a separately approved extension.

This document is a proposed engineering approach. It is not evidence that the software has already been developed, that the five-participant study has occurred, or that any accuracy or security target has been achieved.

01 Executive conclusion

The reviewed MSc proposal is feasible as a controlled research prototype. It identifies a valid cybersecurity question: whether behavior observed during an already-authenticated session can provide additional evidence for access decisions. The proposed inputs - keystroke timing, mouse interaction, application activity and login/session context - can be studied through a consent-based web portal, and standard machine-learning methods can provide user-specific anomaly estimates. The result can enforce allow, step-up authentication, restriction and revocation decisions on a genuinely protected web resource.

MAIN DEVELOPMENT DECISION

Retain the client's research objectives, but make the first deliverable a **Zero-Trust resource-access platform with behavioral continuous authentication**. Add actual network admission using 802.1X/RADIUS only if the supervisor requires controlling physical wired or wireless connectivity.

What will be retained

- The existing project title, research motivation and three stated objectives (proposal §1.3).
- Five consented research participants, multiple collection sessions, genuine/impostor labels (proposal §§3.3-3.4).
- Approved keystroke and mouse metrics, observation windows and model comparison (proposal §§3.4-3.6).
- Dynamic low/medium/high-risk responses and evaluation of security and usability (proposal §§3.7, 3.9-3.11).

What will be added

A precise enforcement boundary; operational identity provider and MFA; session-aware experimental design; numerical telemetry quality controls; model-score calibration; stateful server-side session revocation; device-posture limitations; a real test lab; security hardening; and repeatable deployment/acceptance criteria.

Interpretation boundaries

INCLUDED IN CORE BUILD	NOT AUTOMATICALLY INCLUDED
Behavioral telemetry inside the protected browser portal	Global monitoring of keyboard/mouse activity across the operating system
Real protected web-resource authorization	802.1X admission to an Ethernet switch or Wi-Fi access point
Per-user five-participant academic experiments	Production-strength biometric identity proof for large user populations
Server-side policy enforcement and security logs	Autonomous certainty that a behavioral deviation proves an impostor

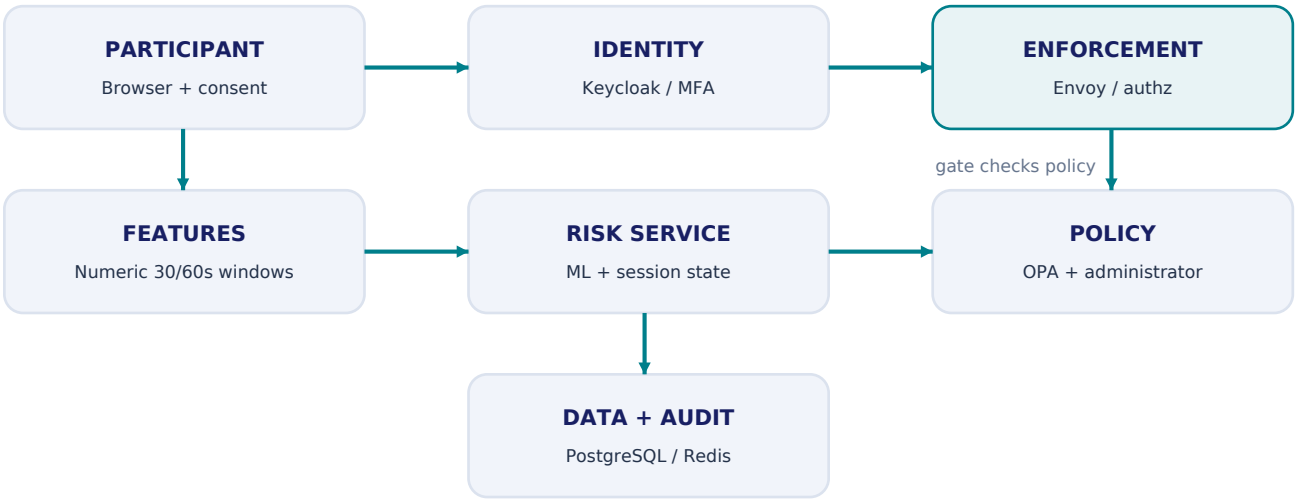
02 Findings from the submitted proposal

The points below distinguish **what the document actually proposes** from **the developer's recommended changes**. Section references identify the corresponding chapters of the submitted client document.

PRIORITY / PROPOSAL REFERENCE	GAP OR IMPLEMENTATION RISK	PROPOSED ACTION
Critical §§2.4, 3.3, 3.7	It describes application/resource access and mentions “network level,” but no switch, proxy, PEP or enforceable network path is specified.	Protect resources behind Envoy; perform per-request server-side checks through OPA. Add optional 802.1X only after scope approval.
Critical §§3.4, 3.8	The browser portal and optional laptop agent are interchangeable in the narrative although their observation capabilities differ.	Fix baseline as browser-only and collect exclusively within the portal; defer host-wide agent to separate scope.
High §§1.3, 3.3	Device posture is an objective but no trustworthy endpoint health measurement is defined.	Use registered-device/session context, clearly marked as context not attestation; optional managed agent later.
High §§3.4, 3.11.1	Only five users are planned; number of sessions and device/day diversity are not fixed.	Prespecify repeat sessions, consent and genuine/impostor scenarios, and limit external-validity claims.
Critical §§3.6, 3.11.1	A generic 70/15/15 random split may leak near-identical windows from one session into training and testing.	Group by session and freeze a held-out test set. Fit scaling only on training data.
High §§3.6-3.7	The proposal does not state how raw model scores become a calibrated risk band.	Compare statistical / Isolation Forest / One-Class SVM / supervised baselines; calibrate on validation data.
High §§3.7-3.9	MFA, restriction and blocking are described without protocol-level flow or enforcement verification.	Implement Keycloak challenge flows, a policy state machine and real gateway denial/revocation tests.
High §3.11.2	Confusion matrix uses legitimate=positive, which is valid only if consistently maintained; FAR/FRR interpretations can then be confusing.	Standardize positive=impostor throughout the implementation; report denominator definitions explicitly.
High §§2.7, 3.5	“Continuous” verification ignores idle or hidden-page periods with insufficient signals.	Add insufficient-evidence state, inactivity policy and tested observation windows.
High §§3.4, 3.10	The ethical statement excludes typed text but lacks implementable collection exclusions/retention workflow.	Aggregate numeric features in the browser; exclude password/OTP/private fields; implement consent, withdrawal, retention.
Medium §3.9	Testing categories are given, but acceptance cases, deployment requirements and reproducibility are absent.	Define test IDs, evidence, metrics, repeatable local lab, source/infra packages and operational runbooks.

03 Solution architecture and trust boundaries

The solution places a dedicated Policy Enforcement Point in front of every protected web resource. Authentication and policy controls are authoritative at the server; the browser collects behavioral evidence but does not decide access. Machine learning is a risk input to deterministic, auditable policy decisions.



Logical flow: (1) Authenticate user with Keycloak; (2) establish a server-managed session; (3) protect API/resources through Envoy ext_authz; (4) aggregate consented behavior in the browser; (5) validate and score the windows with a per-user model; (6) update risk and session state; (7) evaluate policy in OPA; (8) permit, require MFA, restrict, or revoke future resource access; (9) record audit evidence in PostgreSQL.

Enforcement boundary

The protected resource is placed only on an internal container network. No direct host port is published for that resource. Envoy must check the current state for protected requests; a revoked session must fail the next request even if its browser cookie remains locally present. A “blocked” badge on a dashboard is not sufficient evidence of successful enforcement.

Scope of actual user verification

Browser events are captured only when the monitored portal is focused and the user interacts with approved controls. JavaScript cannot observe arbitrary Windows applications or prove that browser-provided telemetry originated from a specific human. A browser-only classifier is therefore a supporting authentication signal, not a cryptographic identity credential.

04 Technology stack and implementation rationale

LAYER	PREFERRED IMPLEMENTATION	ROLE IN DELIVERABLE
Frontend	React, TypeScript, Vite, Tailwind CSS	Consent/enrollment portal, secured resource client, administrative dashboard
Identity and MFA	Keycloak, OIDC Authorization Code, TOTP	Credential authentication, MFA and supported step-up/reauthentication
API and orchestration	Python, FastAPI, Pydantic	Sessions, ingest, authorization adapter, evaluation and reporting
Policy	Open Policy Agent (Rego)	Risk/role/resource policy decisions; default deny
Enforcement	Envoy HTTP ext_authz	Real protected web/API access checks
ML/data science	Scikit-learn, Pandas, NumPy, Joblib	Feature preparation, per-user models, comparison and inference
State and database	Redis + PostgreSQL + Alembic	Current authorization/session state plus audit/history/migrations
HTTPS edge	Caddy, TLS	Single authenticated ingress for server deployment
Packaging	Docker Compose	Local and single-server reproducible stack
Validation	Pytest, Playwright, OPA tests, Locust	Unit, integration, security, end-to-end and performance verification
Developer toolchain	Windows 11 + WSL2 Ubuntu, VS Code, Git	Build, test, run and maintain the project

All versions must be selected from mutually compatible maintained releases, pinned in lockfiles/images, and documented after the repository is built. No external commercial service or licensed enterprise security appliance is required for the first research prototype.

05 Data collection, consent and feature engineering

Research participants and tasks

Five consenting participants form the minimum proposed cohort. I recommend six to eight collection sessions per participant, preferably spread across different days; each session may contain approximately 10-15 minutes of typing/navigation/mouse tasks. The schedule is a proposed protocol, not a claim that data has already been collected. Controlled impostor trials use approved test identities and explicit participation; genuine labels are not inferred from an ML score.

SIGNAL	EXAMPLE NUMERIC FEATURES	DESIGN SAFEGUARD
Keystroke	Hold-time distribution; inter-key intervals; pause variability; typing pace	Never capture characters, text strings, passwords, OTP fields or clipboard content
Pointer/mouse	Speed and acceleration distribution; direction changes; click intervals	Aggregate in-memory and discard raw coordinate sequences
Scrolling/navigation	Scroll frequency; navigation event counts; task time	Only approved portal interactions; no outside browsing history
Session context	Local task state, active/idle duration, browser visibility, approved device label	Context is not trusted hardware attestation

Observation-window design

Use configurable 30- and 60-second windows, requiring a documented minimum count and quality of events. A window with too little activity must yield **INSUFFICIENT_EVIDENCE**, not a forced “legitimate” or “impostor” prediction. Maintain feature-schema versions and per-window deduplication, and compare the latency/quality trade-off of both durations.

Privacy and research ethics

Implement explicit opt-in and purpose statements, consent timestamps, withdrawal support, participant pseudonyms, access controls, retention/deletion procedures and dataset export restrictions. Browser event handling must deliberately exclude password, TOTP, other sensitive inputs and private content. Even numeric behavioral biometrics may be personally identifying; secure storage and approved research access remain necessary.

06 Machine-learning methodology

The research will compare defensible baselines rather than selecting one algorithm in advance. Each individual is a claimed identity with genuine enrollment data. Models estimate the consistency of future observation windows with that enrolled profile; model scores are not automatically calibrated probabilities of compromise.

EXPERIMENT	TRAINING INPUT	DECISION / EVALUATION
Robust statistical distance	Genuine user enrollment windows	Transparent benchmark and feature-wise deviation analysis
Isolation Forest	Genuine windows by participant	Per-user anomaly ranking; tune threshold on validation
One-Class SVM	Genuine standardized windows	Novelty detector requiring careful scaling/parameter selection
Random Forest	Labeled genuine/impostor training sessions, if sufficient	Supervised comparison for known impostors, not proof of unknown-attack coverage

Research validity controls

- Split the dataset by **entire session** (and chronologically where appropriate). Never place windows from the same session on both sides of a train/test boundary.
- Fit preprocessing parameters on the training subset only. Tune model thresholds on validation data and freeze the final test set.
- Use an explicit positive label of **impostor**; report TP, TN, FP and FN consistently.
- Measure False Acceptance Rate (impostor attempts accepted / total impostor attempts), False Rejection Rate (genuine attempts rejected / total genuine attempts), F1, recall, precision, per-user performance and usability costs.
- Record the participant count, genuine/impostor session counts, usable windows, device/task distribution, model version, seed, split manifest and uncertainty.
- Provide synthetic fixtures solely for automated tests/demo; report empirical accuracy only for genuinely collected, consented research data.

Model deployment and model governance

Create a model registry with user ID, schema version, artifact checksum, training provenance, candidate/active status, threshold, validation summary and promotion audit. Unenrolled or missing-model users must enter an explicit onboarding/fallback state. No system should treat an anomalous score alone as a “confirmed impostor.”

07 Access-control workflow

SYSTEM STATE	TRIGGER / CONDITIONS	ENFORCEMENT
Unauthenticated	No valid login/session	Deny protected resources; redirect to identity provider
Authenticated, not enrolled	Valid identity but no qualified model	Permit only onboarding/low-sensitivity services per policy
Allowed	Valid role, consent/status and acceptable risk evidence	Permit authorized resource methods only
Challenge	Moderate risk or expired authentication assurance	Require actual Keycloak MFA/reauthentication; protect sensitive resources
Restricted	Persistent elevated risk or policy violation	Deny high-value operations, allow only bounded remediation
Revoked	Corroborated high risk or administrative action	Invalidate server session, deny subsequent requests, audit
Insufficient evidence	Idle/inactive/hidden page or poor signal quality	Use documented fallback/recheck policy, not false biometric certainty

The backend maintains authoritative state in Redis with persisted audit records in PostgreSQL. OPA evaluates identity, role, resource, method, authentication strength, risk band, observation quality and session expiry. A high-impact automated action should require validated thresholds and suitable corroboration, with recovery/appeal procedures.

Real-world scenario

A legitimate enrolled employee logs in, passes MFA and opens an approved document. The gateway allows this request. During the session, approved interaction features are aggregated, evaluated and logged. When the risk policy requires stronger authentication, access to protected operations is held until a genuine MFA flow completes. If a session is revoked, a fresh attempt to download the document is rejected by Envoy even if the page itself still displays cached content.

08 Build, setup and test laboratory

ENVIRONMENT	BASELINE CONFIGURATION
Developer workstation	Windows 11 + WSL2 Ubuntu, Docker Desktop/Engine, VS Code, Node, Python, Git
Suggested resources	16 GB RAM minimum for a constrained setup; 32 GB preferable; 4-8 cores and ~80 GB available storage
Test clients	Participant browsers on the host or additional laptops/VMs; isolated research/test accounts
Identity/policy infra	Keycloak, OPA, Envoy, backend, PostgreSQL, Redis in isolated Compose services
Networking	Internal-only protected-service network; externally visible HTTPS edge; no direct resource bypass
Data storage	Persistent database volume, backups, consent and model directories with restricted access
Research tooling	Session registration, grouped split manifests, reproducible training and evaluation scripts

Environment sequence

- Install and validate development prerequisites; inspect existing repository, preserving source and Git history.
- Provision containers, health checks, databases/migrations and IdP realm; verify local HTTPS/auth.
- Implement the protected resource, Envoy policy gateway and default-deny tests before building the full dashboard.
- Deploy participant enrollment tasks and validate numeric-only feature capture and consent exclusion tests.
- Collect controlled data; train and validate per-user models without session leakage.
- Integrate risk state, authentication challenge, role restrictions and immediate server-side revocation.
- Run the complete security and behavioral experiment matrix; produce evidence, figures and a repeatable demo script.

09 Verification and acceptance matrix

Each test must record inputs, timestamps, expected result, actual result and a pass/fail determination. Tests that require genuine participant data cannot be counted as passed using synthetic fixtures alone.

ID	TEST / MEASUREMENT	ACCEPTANCE EVIDENCE
F01	Valid/invalid authentication; MFA/step-up	IdP result, session state and authorized/unauthorized HTTP status
F02	Role-based and resource authorization	Privileged operations denied to non-authorized participants
F03	Protected upstream bypass attempt	No host-exposed upstream port; request reaches gateway only
F04	Server-side session revocation	Next protected HTTP request denied after revocation
F05	Challenge/restriction recovery	Only actual completed reauthentication changes session access
D01	Consent, exclusion of typed content	Automated collector tests prove no passwords/characters/raw text stored
D02	Idle, focus loss and hidden browser	Insufficient-data policy; no fabricated user identification
D03	Invalid/replayed behavioral data	Server rejects cross-user IDs, duplicates, malformed windows
M01	Five-user genuine/impostor evaluation	Session manifest with labeled participants and held-out sessions
M02	Algorithm comparison	Consistent metrics and correct impostor-positive confusion matrix
M03	30 vs 60-second windows	Detection delay, usable-sample fraction, FAR/FRR reported
M04	Missing model, model version mismatch	Documented safe fallback; integrity checks
S01	Authz service/policy store failure	Protected access fails closed per defined failure policy
S02	Cross-user and admin access testing	RBAC denies unauthorized data and administrative mutations
P01	Latency/load tests	Observed p50/p95 gateway/authz latency, model inference time and resource use
O01	Redeploy/restart and backup restore	Services recover and model/database state persists

Performance metrics and reporting

Report the false acceptance/rejection rates, precision, recall, F1 and confusion matrix per model and per participant, plus test-set size and coverage. Measure detection time from onset of controlled impostor activity to decision; separately measure enforcement time from decision to the first denied protected request. Include false MFA challenges, wrongful restrictions, usability feedback, latency and resource overhead.

10 Local and server deployment approach

Local research/demo deployment

Use Docker Compose under Ubuntu/WSL2 to start the identity provider, APIs, policy engine, model worker, gateway, database, Redis and both portals. Deliver `.env.example`, pinned dependencies, health checks, repeatable database migrations, clearly synthetic test fixtures and scripts for startup, shutdown, testing, backup and restore. Provide a controlled user enrollment and impostor-trial guide.

Single-server Linux deployment

Supply an additional production Compose configuration for a supported Ubuntu LTS server or authorized VPS: valid domain and TLS, restrictive firewall, external exposure only for intended ingress ports, managed secrets, non-public databases and upstream resources, container restart/health policies, persistence, encrypted backups, versioned migration/rollback process, administrator MFA and monitored logs. Actual remote deployment requires client-provided infrastructure, DNS access and authorization.

Optional genuine physical network NAC

If formally requested and approved, implement a second phase with a compatible 802.1X switch/access point, FreeRADIUS, EAP-TLS, user/device certificates, authorized/quarantine VLANs and dynamic session updates where supported. Add tests showing an endpoint's network admission changes in response to risk. This hardware phase is not necessary to validate the behavioral-learning research question and is not included in the baseline software acceptance.

11 Execution schedule and deliverables

STAGE	INDICATIVE PERIOD	OUTPUT / GATE
1. Discovery & architecture	Weeks 1-2	Agreed scope, threat model, consent protocol, acceptance criteria
2. Identity and enforcement	Weeks 3-4	Working OIDC/MFA and protected-resource gateway with deny tests
3. Behavioral collection	Weeks 5-6	Consent-based portal, numeric feature windows and collector tests
4. Research dataset	Weeks 7-8	Genuine/impostor research sessions and immutable split manifests
5. ML experiments	Weeks 9-10	Comparable trained models, validation thresholds and research metrics
6. Dynamic risk controls	Weeks 11-12	Policy states, real challenge/restriction/revocation and audit
7. Full verification	Weeks 13-14	Automated tests, performance, security and evidence reports
8. Handover	Weeks 15-16	Local/production deployment runbooks, source and final demo

This 16-week plan is indicative, not a contractual fixed-time guarantee. Participant availability, quality/quantity of captured samples, identity-provider integration and enforcement hardening are

schedule dependencies. Physical 802.1X integration requires separate equipment, testing time and approval.

Final delivery inventory

- Complete modular code repository, environment manifests, infrastructure configurations and test scripts.
- Participant login/enrollment portal, protected demo resource and administrative monitoring dashboard.
- Versioned ML feature/benchmark pipelines, model registry, empirical figure/table generation and experiment metadata.
- Authenticated, policy-controlled gateway and demonstrable allow/challenge/restrict/revoke security states.
- Documented test evidence, research limitations, privacy procedures, local and Linux server runbooks, backup/restore procedures.

12 Client approvals, exclusions and risks

Approval items before development

- Confirm whether application/resource ZTNA is acceptable for the approved MSc title, or whether physical 802.1X network admission is compulsory.
- Approve ethical consent wording, selected participants, the number/timing of sessions and controlled impostor procedure.
- Confirm whether local demonstration is sufficient or a public/organizational server deployment is expected; provide authorized hosting/domain where applicable.
- Confirm required institutional format for diagrams, evaluation plots, code artifacts, dissertation material and final evidence.
- Confirm ownership, confidentiality, research-data access, retention and who may receive participant-level datasets.

Explicit exclusions from baseline

No covert keylogging; no monitoring of arbitrary operating-system applications; no interception of actual passwords/OTP characters; no unconsented biometric data; no promise of perfect impersonation detection; no claim of generalizable enterprise accuracy from five users; no physical 802.1X admission equipment; no unapproved public deployment; no unperformed tests or invented performance statistics.

Principal project risks and mitigations

RISK	IMPACT	MITIGATION
Five-person sample / variation	Weak generalization, unstable thresholds	Multiple days/sessions, group splits, confidence limitations
Behavior changes or inactivity	Unnecessary blocks or delayed detection	Quality flags, smoothing, step-up before high-impact revocation
Client telemetry forgery	Behavior scores can be manipulated	Treat as weak corroborating signal; protect IdP/session/gateway
Gateway/IdP misconfiguration	Policy bypass or lockout	Default deny, private upstream, end-to-end enforcement tests
Sensitive behavioral records	Privacy and ethics exposure	Numeric-only capture, consent, pseudonyms, retention, RBAC
Hardware expectation mismatch	Misaligned deliverable	Approve app-layer vs network-layer acceptance in writing

SCOPE DECISION REQUESTED FROM THE CLIENT

Please approve the **application/resource access prototype** as the primary MSc research implementation. If the academic supervisor requires actual Ethernet or Wi-Fi admission, authorize the separate hardware-enabled 802.1X workstream and corresponding acceptance tests.

13 References and source traceability

Client-provided source: Oso Akinyemi Seun, Development of a Zero-Trust Network Access Control System Using Machine Learning-Based Behavioral Authentication, MSc research proposal, University of Ilorin, October 2025. Relevant sections: §1.3 objectives; §§2.3-2.7 conceptual model; §§3.3-3.8 architecture, collection and ML; §§3.9-3.11 tests, ethics and evaluation.

External engineering references (official documentation):

NIST SP 800-207, Zero Trust Architecture: https://csrc.nist.gov/pubs/sp/800/207/final

NIST SP 800-207A, Cloud-Native Application Access: https://csrc.nist.gov/pubs/sp/800/207/a/final

OPA - Envoy plugin: https://www.openpolicyagent.org/docs/envoy

Keycloak - OpenID Connect: https://www.keycloak.org/securing-apps/oidc-layers

Keycloak - Server Administration Guide: https://www.keycloak.org/docs/latest/server_admin/

Scikit-learn - GroupShuffleSplit: https://scikit-learn.org/stable/modules/generated/sklearn.model_selection.GroupShuffleSplit.html

MDN - Page Visibility API: https://developer.mozilla.org/en-US/docs/Web/API/Page_Visibility_API

Docker Compose in production: https://docs.docker.com/compose/how-tos/production/

Approval note: This report is intended as a developer-to-client feedback memorandum. The research design, implementation boundaries, security assumptions and optional physical-NAC extension should be approved before coding starts. Performance and model-selection conclusions remain empirical until actual study data is collected and tested.